COMPREHENSIVE TECHNICAL ANALYSIS

Pegasus Zero-Click Exploit

FORCEDENTRY (CVE-2021-30860) — How It Works, Exploit Chain, Timeline, Current State in 2026, and How to Protect Yourself

Exploit Name	FORCEDENTRY (CVE-2021-30860)
Attack Type	Zero-Click — no user interaction whatsoever
Entry Vector	Apple iMessage — automatic background attachment processing
Developed By	NSO Group (Israeli cyberweapons firm)
Discovered By	Citizen Lab, University of Toronto — August 2021
Apple Patch	iOS 14.8 — Emergency update, September 13, 2021
Current Status (2026)	FORCEDENTRY patched; NSO continues with new zero-days; active threat ongoing
2026 Latest CVE	CVE-2026-20700 (dyld memory bug) + CVE-2025-14174 + CVE-2025-43529 (WebKit)
Google Project Zero Rating	One of the most technically sophisticated exploits ever seen
Affected Targets	50,000+ phone numbers identified globally (journalists, activists, politicians)

Table of Contents

1. What Is Pegasus Spyware? 3
1.1 What Pegasus Can Do Once Installed 3
1.2 Who Sells It and to Whom 3
2. Complete FORCEDENTRY Exploit Chain — Step by Step 4
3. How It Works — The JBIG2 Integer Overflow & Virtual CPU 5
3.1 The JBIG2 Format 5
3.2 The Integer Overflow Bug (CVE-2021-30860) 5
3.3 The Virtual Turing Machine Inside the Image 5
4. Complete Timeline — Pegasus Evolution (2016–2026) 7
5. Attack Architecture — How the Pieces Fit Together 9
5.1 Attack Surface: Why iMessage? 9
5.2 The Fake GIF Trick — Expanding the Attack Surface 9
5.3 Memory Exploitation Detail 9
5.4 Why PAC (Pointer Authentication Codes) Didn't Stop This 10
6. Forensic Detection — The CASCADEFAIL Artifact 11
6.1 The SQLite Artifact 11
6.2 Other Forensic Indicators 11
7. Current State in 2026 — Is the Threat Still Active? 12
7.1 What Has Changed Since FORCEDENTRY 12
7.2 The Commercial Spyware Landscape in 2026 13
7.3 Will Pegasus-Style Attacks Affect You in 2026? 13
8. How to Protect Yourself From Pegasus and Zero-Click Attacks 14
8.1 Protection Measures — Comprehensive Table 14
8.2 Lockdown Mode — The Most Powerful Defense 15
8.3 What Does NOT Work Against Pegasus 16
9. Legal and Political Landscape 17
9.1 Legal Actions Against NSO Group 17
9.2 Why Legal Action Has Not Stopped the Threat 17
10. Key Technical Takeaways and Lessons 18
10.1 For Security Researchers 18
10.2 For Security Defenders 18
10.3 For High-Risk Individuals 18
11. Will This Affect Users in 2026? — Definitive Answer 20

1. What Is Pegasus Spyware?

Pegasus is a military-grade surveillance spyware suite developed by the NSO Group — an Israeli cyber-arms company founded in 2010. It is sold exclusively to vetted governments and state intelligence agencies, with each sale requiring approval from the Israeli Ministry of Defense. NSO Group markets Pegasus as a tool for fighting terrorism and serious crime. In practice, it has been used against journalists, lawyers, human rights defenders, politicians, and dissidents across the world.

1.1 What Pegasus Can Do Once Installed

Full Device Compromise — Pegasus Capabilities
• Read all messages: SMS, iMessage, WhatsApp, Signal, Telegram, Gmail — even encrypted apps
• Intercept phone calls and VoIP calls in real time
• Activate the microphone and camera silently and at will
• Track GPS location continuously
• Harvest all stored passwords and authentication tokens
• Exfiltrate photos, contacts, calendar entries, browsing history
• Keylog — capture every keystroke typed
• Access app data from any installed application
• Self-destruct — remove all traces after completing a surveillance mission

1.2 Who Sells It and to Whom

NSO Group is headquartered in Herzliya, Israel. It employs former Israeli military intelligence (Unit 8200) officers. Pegasus is sold to governments only, with contracts reportedly running $7–$8 million or more per country. Known client countries include Saudi Arabia, UAE, Mexico, India, Azerbaijan, Kazakhstan, Rwanda, Morocco, Hungary, and others. The U.S. added NSO Group to its Entity List in November 2021, prohibiting American companies from doing business with the firm.

2. Complete FORCEDENTRY Exploit Chain — Step by Step

The following is a detailed visual flowchart of the entire FORCEDENTRY exploit chain, from the moment the attacker sends the malicious iMessage to the moment Pegasus is fully installed and operational on the victim's device. No user interaction is required at any stage.

①	**DELIVERY — Malicious iMessage Sent**	Attacker sends a specially crafted message to the target's phone number or Apple ID. The message contains one or more files named with a .gif extension. These files are not actual GIFs — they are secretly Adobe PDF documents containing JBIG2-encoded image streams, or Adobe PSD files. The victim sees nothing unusual (often nothing at all).
②	**AUTO-PROCESSING — iMessage Background Parsing**	iOS automatically processes all incoming iMessage attachments in the background before the user opens the Messages app. The file's .gif extension causes iMessage to route it through over 20 different image codec parsers — including the JBIG2 decoder in Apple's CoreGraphics framework. This routing happens inside the IMTranscoderAgent background process.
③	**BLASTDOOR BYPASS — Outside the Sandbox**	Apple's BlastDoor sandbox (introduced in iOS 14 to prevent zero-click attacks) would normally contain any exploit. However, FORCEDENTRY targeted the CoreGraphics/IMTranscoderAgent pathway, which ran OUTSIDE the BlastDoor sandbox. The exploit does not break BlastDoor — it simply goes around it entirely.
④	**TRIGGER — CVE-2021-30860 Integer Overflow**	The JBIG2Stream::readTextRegionSeg function in CoreGraphics calculates numSyms by summing values from multiple SymbolDict segments. Two large 32-bit unsigned integers overflow back to a tiny number (e.g. 0x80000000 + 0x80000001 = 0x00000001). A heap buffer called syms is allocated at this tiny size, but the loop that fills it uses the original large sizes — writing gigabytes of attacker-controlled data past the buffer boundary.
⑤	**VIRTUAL CPU — Turing-Complete Machine in JBIG2**	NSO Group's most remarkable innovation: over 70,000 JBIG2 segment commands are used to construct a complete virtual 64-bit computer inside the image decompression pass itself. This VM has: 64-bit registers, a 64-bit adder, a comparator, memory read/write, and conditional branching — all built from JBIG2's logical bitmap operations (AND, OR, XOR, XNOR). This completely bypasses PAC (Pointer Authentication Codes), ASLR, and CFI because no native code is executed.
⑥	**RCE INSIDE SANDBOX — Fake Objective-C Object**	The virtual CPU executes a bootstrapping program that constructs a fake JBIG2Segment object in heap memory with a corrupted virtual function table (vtable). Calling a virtual function on this fake object triggers a jump to attacker-controlled code. An NSKeyedArchiver blob is deserialized containing an NSFunctionExpression — Apple's Objective-C query engine. This achieves arbitrary Objective-C code execution inside IMTranscoderAgent.
⑦	**SANDBOX ESCAPE — Logic Bug via CommCenter**	Pure logic bugs (no memory corruption) are used for the sandbox escape. A malicious NSPredicate object is routed to the CommCenter process via an IPC channel (com.apple.commcenter) — accessible from within the IMTranscoderAgent sandbox. CommCenter runs with higher privileges. Arbitrary Objective-C method calls execute in CommCenter's context. PAC, ASLR, and all hardware mitigations are irrelevant to this stage.
⑧	**PRIVILEGE ESCALATION — Kernel Exploit**	A separate kernel-level vulnerability is used to escalate from CommCenter privileges to kernel (root) privileges — completing a full jailbreak of the device. The kernel exploit details are not fully public, but the dyld_shared_cache slide being 0 in crash logs confirmed ASLR was already defeated before this stage.
⑨	**PEGASUS INSTALLED — Silent Jailbreak**	The Pegasus payload is silently deployed and the device is fully jailbroken. Surveillance begins: messages, calls, microphone, camera, GPS, passwords. After mission completion, Pegasus self-destructs to minimize forensic traces — but the CASCADEFAIL artifact in DataUsage.sqlite databases remained, providing forensic evidence of infection.

ZERO USER INTERACTION The entire chain from Stage 1 to Stage 9 executes automatically in the background. The victim receives no notification, sees no unusual activity, and is not asked to click, open, or approve anything. The device is compromised the moment the iMessage is received and processed.

3. How It Works — The JBIG2 Integer Overflow & Virtual CPU

3.1 The JBIG2 Format

JBIG2 (Joint Bi-level Image Experts Group 2) is a legacy compression standard for black-and-white images — primarily designed for compressing text in scanned PDF documents. It works by identifying repeated pixel patterns (glyphs), keeping one reference copy, and replacing all matching occurrences. Apple's CoreGraphics implemented JBIG2 parsing using code from the open-source Xpdf library.

JBIG2 is structured as a series of "segments" — essentially drawing and logic commands executed sequentially. The parser supports 19 segment types. Critically for this exploit, JBIG2 includes logical operations (AND, OR, XOR, XNOR) that operate on rectangular bitmap regions. NSO Group recognized that these operations are Turing-complete.

3.2 The Integer Overflow Bug (CVE-2021-30860)

Vulnerable Code Path — JBIG2Stream::readTextRegionSeg

```
numSyms = 0;

for (i = 0; i < numSymDicts; ++i) {
    numSyms += symDicts[i]->size;   // ← OVERFLOW HERE
}

syms = (JBIG2Sym **)gmallocn(numSyms, sizeof(JBIG2Sym *));  // ← tiny buffer

// Then fills syms using original segment sizes, not overflowed numSyms
// → Writes far beyond end of heap buffer → Heap corruption
```

3.3 The Virtual Turing Machine Inside the Image

After achieving heap corruption, NSO Group did not use traditional shellcode, ROP chains, or JOP gadgets. Instead, they built a small but complete virtual computer using over 70,000 JBIG2 segment commands. This is the aspect Google Project Zero called extraordinary:

Logical Ops Used	AND, OR, XOR, XNOR on bitmap regions — JBIG2's built-in operations
Why Turing-Complete	NAND and NOR gates (derivable from the above) can compute any function
VM Components Built	64-bit registers, 64-bit adder, 64-bit comparator, memory read/write, conditional branch
Commands Required	Over 70,000 individual JBIG2 segment commands in one image stream
Execution Context	Runs entirely inside the JBIG2 decompression pass — no native code

Defenses Bypassed	PAC, ASLR, CFI — all irrelevant because no native code pointer is executed
Goal	Execute the sandbox bootstrapping code in a memory-safe, detection-immune way

UNPRECEDENTED	This is the first publicly documented exploit to build a Turing-complete virtual machine inside an image format's decompression pass. Google Project Zero called it "pretty incredible, and at the same time, pretty terrifying."

4. Complete Timeline — Pegasus Evolution (2016–2026)

Pegasus has continuously evolved since its first discovery in 2016. Each generation introduced new attack vectors and defeated Apple's latest defenses. The pattern is consistent: Apple patches a known exploit, NSO Group acquires or develops a new zero-day, often before the previous one is publicly disclosed.

Aug 2016	**TRIDENT (iOS)**	First discovery. UAE human rights defender Ahmed Mansoor received a suspicious SMS link. Citizen Lab and Lookout identified 3 zero-days (CVE-2016-4655, CVE-2016-4656, CVE-2016-4657). Required 1 click to execute. Apple patched with iOS 9.3.5 emergency update.
2017–18	**Expansion**	Pegasus documented targeting journalists and activists in Mexico, UAE, Saudi Arabia. Android version (Chrysaor) discovered by Google/Lookout. Infrastructure identified in 45+ countries.
May 2019	**WhatsApp VoIP**	Zero-click via missed WhatsApp audio call (CVE-2019-3568). Attack triggered in call handling code before user answered. WhatsApp patched and later filed landmark lawsuit against NSO Group.
2019–20	**KISMET (iMessage)**	Zero-click iMessage exploit targeting iMessage image parsing. Required no user interaction. Defeated Apple's then-current security architecture. Patched in iOS 14 with introduction of BlastDoor.
iOS 14 (2020)	**BlastDoor Deployed**	Apple introduced BlastDoor — a tightly sandboxed service specifically to pre-process iMessage content and contain any parser exploits. BlastDoor successfully stopped the KISMET exploit. Security community praised it as a significant defense.
Jul–Sep 2021	**FORCEDENTRY**	NSO Group bypassed BlastDoor entirely using CVE-2021-30860 — a JBIG2 integer overflow in CoreGraphics, routed outside the BlastDoor sandbox via IMTranscoderAgent. Built Turing-complete VM inside the image. Used against Bahraini activists, Saudi dissidents, journalists worldwide. Patched iOS 14.8, Sep 13, 2021.
Jul 2021	**Pegasus Project**	17 media organizations published the Pegasus Project — a coordinated investigation based on a leaked list of 50,000+ phone numbers selected as targets. Included heads of state (Emmanuel Macron, Imran Khan), journalists, human rights workers.
Nov 2021	**U.S. Sanctions**	U.S. Commerce Department added NSO Group to the Entity List, blocking American companies from supplying NSO. Apple sued NSO Group. Legal escalation begins worldwide.
Sep 2023	**BLASTPASS**	New zero-click exploit (CVE-2023-41064) targeting Apple's image processing for PassKit attachments. No user interaction needed. Patched with iOS 16.6.1. Demonstrated NSO continued acquiring new zero-days post-sanctions.
Dec 2024	**Active Infections Found**	iVerify researchers scanning 2,500 opted-in devices found 7 new Pegasus infections targeting journalists and executives — across

		iOS 14, 15, and 16.6 — infections initiated between 2021 and 2023 still active.
May 2025	**NSO Loses WhatsApp Case**	U.S. jury ordered NSO Group to pay $167.3 million in punitive damages and $444,719 in compensatory damages to Meta/WhatsApp for the 2019 WhatsApp exploit. First major legal victory against NSO Group.
Oct 2025	**Permanent Injunction**	U.S. District Court issued permanent injunction prohibiting NSO Group from targeting WhatsApp users. Punitive damages reduced to ~$4M on appeal but injunction stands. NSO Group's legal situation worsens.
Dec 2025	**WebKit Zero-Days Patched**	CVE-2025-14174 and CVE-2025-43529 — critical WebKit memory corruption flaws allowing code execution via crafted images/PDFs — patched in iOS. Used in active targeted attacks. Apple issues targeted notifications to suspected victims.
Feb 2026	**CVE-2026-20700 (dyld)**	First actively exploited zero-day of 2026 — a 20-year-old memory corruption bug in dyld (Apple's Dynamic Link Editor), part of a 3-CVE exploit chain with the Dec 2025 WebKit bugs. Added to CISA Known Exploited Vulnerabilities catalog. iOS 26 patches all three. Apple alerts 1.8 billion users to update.
Mar 2026 (Now)	**CURRENT STATE**	Pegasus-style attacks are actively ongoing. Spyware vendors (NSO Group, Intellexa, Paragon/Graphite) for the first time in 2025 accounted for the highest share of zero-day exploits among all threat actors tracked by Google TAG — surpassing nation-state groups. Commercial spyware is the #1 source of novel zero-days in 2025–2026.

5. Attack Architecture — How the Pieces Fit Together

5.1 Attack Surface: Why iMessage?

iMessage is Apple's default messaging platform. It automatically processes and renders a wide variety of media attachments in the background — entirely without user interaction. This auto-processing is by design (so previews and thumbnails appear instantly). It creates an enormous attack surface: any format that iMessage can process is potentially exploitable.

iMessage Auto-Processing Architecture
IMTranscoderAgent (background daemon): Responsible for transcoding and processing incoming media attachments CoreGraphics framework: Handles image rendering and parsing — supports 20+ image codecs including JBIG2, PSD, PDF, TIFF, etc. BlastDoor sandbox: Apple's defense layer — pre-processes iMessage JSON and some data types in an isolated sandbox
IMDaemon: Core iMessage delivery service SpringBoard: UI process — receives final processed attachments for display KEY INSIGHT: IMTranscoderAgent and CoreGraphics operate OUTSIDE the BlastDoor sandbox for certain media types

5.2 The Fake GIF Trick — Expanding the Attack Surface

File sent	.gif extension — any file with this extension triggers the full codec suite
Actual content	Adobe PDF document containing JBIG2-encoded image streams
Why it works	iMessage routes any .gif file through 20+ image decoders including legacy codecs
Codecs triggered	JBIG2, TIFF, PSD, WebP, BMP, PICT, and 15+ more — each a potential attack surface
BlastDoor impact	None — CoreGraphics processes this file outside the BlastDoor sandbox
User sees	Nothing — processing happens before the notification even appears

5.3 Memory Exploitation Detail

After the integer overflow in numSyms (Stage 4), NSO Group needed to control the heap precisely to make the overflow useful. Here is the memory exploitation sequence:

1. numSyms overflow: Two large SymbolDict segment sizes are added as uint32_t — result wraps around to 1 instead of (e.g.) 4,294,967,297

2. Small allocation: syms buffer allocated as 1 × 8 = 8 bytes
3. Heap grooming: Through careful placement of JBIG2 segments, attacker controls what objects are adjacent to the syms buffer in heap memory
4. Overflow write: The fill loop iterates using original (large) segment sizes, writing gigabytes of attacker data beyond syms — overwriting adjacent heap objects
5. Fake object planted: A carefully crafted fake JBIG2Segment C++ object is written into heap, with a corrupted vtable pointer
6. Virtual dispatch triggered: Code calls a virtual function on the fake object → jump to attacker-controlled code
7. NSKeyedArchiver blob deserialized: Contains NSFunctionExpression triggering arbitrary Objective-C execution

5.4 Why PAC (Pointer Authentication Codes) Didn't Stop This

Apple introduced PAC (Pointer Authentication Codes) in A12-era iPhones to prevent vtable hijacking — one of the most common memory corruption exploitation techniques. PAC signs function pointers with a cryptographic code; using a pointer without the correct signature triggers a fault.

FORCEDENTRY defeated PAC in two ways: First, the JBIG2 Virtual CPU executed entirely without native code execution — PAC has no effect on JBIG2 logical operations. Second, the sandbox escape relied entirely on logic bugs (NSPredicate/NSFunctionExpression) which invoke legitimate Objective-C method calls — all with valid PAC signatures, because they use the real method dispatch infrastructure.

KEY INSIGHT

Logic bugs are the hardest class of vulnerability to defend against with hardware mitigations. PAC, ASLR, sandboxing, and CFI all defend against memory corruption and code injection — but they are powerless against an attacker who uses the system's own legitimate APIs to achieve a malicious result.

6. Forensic Detection — The CASCADEFAIL Artifact

One of the most important forensic discoveries was how Citizen Lab confirmed Pegasus infections. When Pegasus attempts to cover its tracks after a surveillance mission, it deletes database entries that would reveal its presence. However, a bug in its cleanup routine left behind a unique forensic fingerprint named CASCADEFAIL.

6.1 The SQLite Artifact

iOS maintains a database called DataUsage.sqlite that tracks app network usage. It has two relevant tables:

- ZPROCESS: Records each process/app that used network data
- ZLIVEUSAGE: Records actual data usage events, each referencing a ZPROCESS row via ZHASPROCESS

Pegasus deletes its entries from ZPROCESS to hide itself, but fails to also delete the corresponding ZLIVEUSAGE entries. These dangling references — rows that point to non-existent ZPROCESS records — are the CASCADEFAIL signature. It can be detected with a simple SQLite query:

```
SELECT 'CASCADEFAIL' FROM ZLIVEUSAGE WHERE ZLIVEUSAGE.ZHASPROCESS NOT IN (SELECT
Z_PK FROM ZPROCESS);
```

This artifact is uniquely associated with NSO Group's Pegasus across all known infections. It was present on devices of Bahraini activists, Saudi dissidents, and others confirmed infected. Citizen Lab and Amnesty International's Mobile Verification Toolkit (MVT) now scan for CASCADEFAIL as a standard Pegasus indicator.

6.2 Other Forensic Indicators

CASCADEFAIL	Dangling ZLIVEUSAGE rows — most reliable Pegasus indicator
IMTranscoderAgent crashes	Repeated crash logs for IMTranscoderAgent correlating with infection time
DataUsage.sqlite anomalies	Missing ZPROCESS entries for known Pegasus processes
Shutdown logs	Unusual process activity logged in /private/var/db/diagnostics/
Network traffic	Encrypted C2 (command-and-control) connections to NSO infrastructure
Process anomalies	Unknown processes in diagnostic data, crash logs, or battery usage records

7. Current State in 2026 — Is the Threat Still Active?

YES — ACTIVE THREAT	FORCEDENTRY itself is patched. But NSO Group and the commercial spyware industry are more active in 2026 than ever. Spyware vendors — for the first time in 2025 — surpassed nation-state actors as the largest source of novel zero-day exploits tracked by Google's Threat Analysis Group.

7.1 What Has Changed Since FORCEDENTRY

2021	**FORCEDENTRY Patched**	iOS 14.8 closed CVE-2021-30860. Apple sued NSO Group. U.S. added NSO to Entity List. Temporary slowdown in public exploits against latest iOS versions.
2022–23	**New Zero-Days Continue**	BLASTPASS (CVE-2023-41064, Sep 2023) — new zero-click via PassKit. NSO operators documented against iOS 16.6. Demonstrates Entity List had no practical effect on exploit development.
2024	**Infections Confirmed Active**	iVerify found 7 Pegasus infections from 2021–2023 still active on iOS 14/15/16. Multiple Pegasus variants in 5 malware types. Paragon/Graphite spyware emerged targeting journalists via WhatsApp.
2025 Q1	**NSO Legal Losses**	Meta wins $167M jury verdict against NSO Group. Permanent injunction issued against NSO targeting WhatsApp. NSO appeals but injunction stands. Financial pressure mounts.
2025 Full Year	**Spyware Tops Zero-Day Charts**	Google TAG: Commercial spyware vendors in 2025 for the first time collectively surpassed nation-state groups as the largest category exploiting novel zero-days. NSO, Intellexa, Paragon among leaders.
Dec 2025	**WebKit Zero-Days**	CVE-2025-14174 + CVE-2025-43529: Critical WebKit memory bugs — code execution via crafted images/PDFs. Used in targeted attacks before public disclosure. Apple sends targeted notifications to victims.
Feb 2026	**CVE-2026-20700 (dyld)**	20-year-old memory corruption bug in dyld — Apple's dynamic library loader — exploited in the wild. Part of a 3-CVE chain. CISA added to Known Exploited Vulnerabilities. iOS 26 required to be safe. Apple alerts 1.8 billion users.
Mar 2026	**Coruna Exploit Kit**	Google TAG revealed 'Coruna' — an iOS exploit kit with 23 exploits across 5 attack chains — originally from a commercial spyware vendor, leaked to a Russian espionage group, then spread to financially motivated criminal groups. Shows that commercial spyware tools proliferate beyond their original buyers.

7.2 The Commercial Spyware Landscape in 2026

NSO Group is no longer alone. A full industry of commercial surveillance vendors (CSVs) now sells Pegasus-equivalent tools:

NSO Group (Pegasus)	Israel — Pegasus 2 reported active; legal battles ongoing; continues selling to new clients
Intellexa (Predator)	Greece/EU — Predator spyware; EU officials and journalists targeted; under sanctions
Paragon Solutions (Graphite)	Israel — Targeted WhatsApp users; journalists and civil society members in Italy, US, others
QuaDream (Reign)	Israel — Shut down in 2023, but leaked documentation showed Pegasus-level capabilities
Cy4Gate / RCS Labs	Italy — Hermit spyware targeting iOS and Android; documented against journalists in Italy and Kazakhstan
Negg Group	Italy — Mobile surveillance tools tracked by Google TAG
Unknown vendors	Multiple undisclosed CSVs active; Google TAG estimates 40+ spyware vendors globally

7.3 Will Pegasus-Style Attacks Affect You in 2026?

Honest Risk Assessment for 2026
HIGH RISK individuals (primary targets): Journalists, human rights defenders, lawyers on sensitive cases, opposition politicians, executives at companies of strategic interest to governments, diplomats and government officials. MEDIUM RISK individuals: Activists, civil society members, academics researching sensitive topics, family members or associates of high-risk individuals, anyone who received an alert from Apple about state-sponsored attacks.
LOW RISK individuals (general public): The general public is not the primary target of Pegasus or Pegasus-grade spyware. These tools cost millions of dollars per deployment and are used for targeted surveillance, not mass infection. However, the 'Coruna' exploit kit leak shows these tools can proliferate to criminal groups, raising broader risks over time. CRITICAL: A fully patched device running the latest iOS provides significant protection against known exploits. The window of maximum risk is the period between when an exploit is first used in the wild and when Apple patches it — sometimes weeks or months.

8. How to Protect Yourself From Pegasus and Zero-Click Attacks

No protection is absolute against a fully funded, nation-state-backed adversary using undisclosed zero-day exploits. However, a layered security approach significantly reduces your risk and makes targeting you more expensive. Here is a comprehensive protection guide based on current 2026 knowledge:

8.1 Protection Measures — Comprehensive Table

Action	How it Helps	Effectiveness vs Pegasus
Update iOS Immediately	Apple patches exploited zero-days as soon as they are discovered. Unpatched devices are vulnerable to known exploits for months or years.	HIGH — Single most effective defence. CVE-2026-20700 chain (Feb 2026) still affects every iOS device that hasn't updated to iOS 26.
Enable Lockdown Mode (iOS 16+)	Reduces the iMessage attack surface dramatically — disables link previews, attachment auto-processing, most complex media parsers. Also restricts FaceTime, web browsing, USB accessories, and configuration profiles.	VERY HIGH for high-risk individuals. Directly limits the attack surface exploited by FORCEDENTRY. May cause minor usability inconveniences.
Use iVerify or MVT	iVerify (commercial, $1/month) provides behavioral analysis and exploit signals. Amnesty's MVT (free, open-source) performs forensic analysis of device backups for Pegasus indicators including CASCADEFAIL.	DETECTION, not prevention. Useful to identify if you were infected. MVT requires technical knowledge; iVerify is user-friendly.
Reboot iPhone Daily	Pegasus in its documented form does not maintain persistence across reboots on iOS. A daily reboot forces re-exploitation, increasing attacker costs and detection risk.	MEDIUM — Raises attacker costs. Not a guaranteed protection (new variants may achieve persistence, but it's harder to maintain silently).
Disable iMessage / Use Signal	Disabling iMessage removes the primary attack vector for known Pegasus exploits. Using Signal for sensitive communications reduces exposure to iMessage-based zero-clicks.	HIGH for attack vector reduction. Note: Signal itself has been targeted (though less frequently). Does not protect if device is already compromised.
Separate Device for Sensitive Work	High-risk individuals should use a dedicated, isolated device for the most sensitive communications, kept in Lockdown Mode and never used for general browsing or social apps.	HIGH for reducing lateral risk. Standard practice recommended by Citizen Lab for journalists and activists.

Action	How it Helps	Effectiveness vs Pegasus
Apple Threat Notifications	Apple has sent targeted notifications to users it believes were targeted by state-sponsored attackers. Enable these and act immediately if received — update iOS, contact a digital security expert.	HIGH for awareness. Apple has sent thousands of these notifications across dozens of countries. Take them seriously.
Avoid Public / Untrusted Wi-Fi	Some Pegasus deployments have used network injection (attacker on same network redirects traffic to exploit pages). Use a trusted VPN on public networks.	MEDIUM — Reduces network injection risk but does not protect against iMessage-based zero-click delivery.
Audit iMessage Contacts	Be suspicious of unexpected messages — even from known contacts (who may themselves be compromised). Do not open unexpected attachments even from trusted senders.	LOW for zero-click — FORCEDENTRY fires before you open anything. More relevant for 1-click social engineering attacks.
Enterprise MDM + EDR	For organizations: Mobile Device Management combined with Endpoint Detection and Response tools can help detect unusual process activity, network connections, and behavioural anomalies associated with spyware.	MEDIUM — Cannot detect all zero-click infections but improves visibility. iVerify's enterprise tier does device-specific threat hunting.

8.2 Lockdown Mode — The Most Powerful Defense

Introduced in iOS 16, Lockdown Mode is Apple's direct response to Pegasus. It disables or heavily restricts the features most commonly exploited by zero-click attacks. Specifically relevant to FORCEDENTRY:

- iMessage: Most message attachment types are blocked. Link previews disabled. Complex media processing dramatically restricted.
- Web browsing: Just-in-time JavaScript compilation disabled. Complex web technologies restricted. Web fonts blocked.
- FaceTime: Incoming FaceTime calls from unknown contacts blocked.
- USB / accessories: Wired connections to computers and accessories blocked when iPhone is locked.
- Configuration profiles: Installation of custom profiles blocked.

LOCKDOWN MODE RECOMMENDATION	If you are a journalist, activist, lawyer, politician, executive, or anyone who has reason to believe you may be targeted by a state actor — enable Lockdown Mode. Apple designed it specifically to address Pegasus-class attacks. The feature trade-offs are minor compared to the protection it provides.

8.3 What Does NOT Work Against Pegasus

- Antivirus apps from the App Store: iOS sandboxing prevents any app from scanning the full system. These apps cannot detect Pegasus.
- VPNs alone: VPNs protect network traffic but do not prevent iMessage-based zero-click delivery.
- Encrypted messaging apps: Even Signal, WhatsApp, and Telegram cannot protect you once Pegasus has kernel-level access to the device.
- Factory reset (insufficient without re-flashing): Pegasus may persist in some configurations; consult a professional if infection suspected.
- Newer iPhone hardware alone: Hardware defenses like PAC and ASLR were defeated by FORCEDENTRY. New hardware without software updates does not help.

9. Legal and Political Landscape

9.1 Legal Actions Against NSO Group

Nov 2021	**Apple Lawsuit**	Apple sued NSO Group and parent company OSY Technologies for surveilling and targeting iPhone users. Seeking permanent injunction barring NSO from using Apple's software, services, or devices.
Nov 2021	**U.S. Entity List**	U.S. Commerce Department added NSO Group to Entity List. American companies prohibited from selling or supplying NSO without a license. Major constraint on NSO's technology supply chain.
Dec 2024	**WhatsApp Liability Ruling**	U.S. court ruled NSO Group liable for hacking 1,400 WhatsApp users via Pegasus in 2019, violating the Computer Fraud and Abuse Act and the California Computer Data Access and Fraud Act.
May 2025	**$167M Damages**	U.S. jury awarded Meta/WhatsApp $167.3 million in punitive damages and $444,719 in compensatory damages — landmark verdict in spyware accountability.
Oct 2025	**Permanent Injunction**	U.S. District Court Judge Phyllis Hamilton issued permanent injunction prohibiting NSO Group from targeting WhatsApp users. Punitive damages reduced to ~$4M on appeal.

9.2 Why Legal Action Has Not Stopped the Threat

Despite the legal pressure, Pegasus-style surveillance continues because: (1) NSO Group continues to operate and develop new exploits while appeals proceed; (2) other commercial surveillance vendors (Intellexa, Paragon, etc.) are not yet subject to the same legal constraints; (3) governments that purchase these tools have sovereign immunity and cannot easily be sued; (4) the exploit development market is global and operates in jurisdictions with minimal oversight.

10. Key Technical Takeaways and Lessons

10.1 For Security Researchers

- Legacy media codecs (JBIG2, PSD, TIFF) inside widely-deployed parsers (CoreGraphics) remain extremely high-value attack surfaces. File extension-based codec routing expands this surface dangerously.
- Logic bugs that abuse legitimate system APIs (NSPredicate, NSFunctionExpression) are immune to hardware mitigations. These represent the hardest class of vulnerability to defend.
- Turing-complete computation can be hidden inside the data being processed — not just the code processing it. JBIG2 logical operations illustrate this with unprecedented sophistication.
- The gap between sandbox escape and privilege escalation is bridgeable with carefully-chosen IPC channels. CommCenter's accessibility from IMTranscoderAgent was a critical design oversight.
- Forensic artifacts (CASCADEFAIL) can survive even after active cleanup efforts by malware. Incomplete cleanup routines are a consistent weakness in even sophisticated toolkits.

10.2 For Security Defenders

- Default-deny on media processing: restrict which codecs are exposed to untrusted input. Lockdown Mode demonstrates this is feasible without catastrophic usability loss.
- Defense-in-depth remains essential: BlastDoor was a good control but covered only part of the iMessage attack surface. Multiple independent defensive layers are necessary.
- Patch immediately: The window between first exploitation in the wild and public patch is the highest-risk period. Historical Pegasus data shows this window can be months long.
- Deploy detection tools: iVerify and MVT provide real-world detection capability for known Pegasus indicators. Organizations handling sensitive information should run regular scans.
- Architect for harm reduction: Even unbreakable security cannot be guaranteed against a well-funded adversary. Design systems to minimize the impact of a compromise — segment networks, use hardware security keys, maintain out-of-band communication channels.

10.3 For High-Risk Individuals

Practical Security Checklist for High-Risk Users (2026)
✓ Update to iOS 26 (or latest available) immediately — patches CVE-2026-20700 + WebKit chain
✓ Enable Lockdown Mode — single most effective Pegasus countermeasure available
✓ Reboot your iPhone daily — disrupts Pegasus persistence
✓ Install iVerify — behavioral monitoring and exploit detection alerts

✓ Do NOT ignore Apple Threat Notifications — if you receive one, act immediately
✓ Use Signal for sensitive communications — reduce iMessage exposure
✓ Consider a separate, Lockdown Mode device for your highest-sensitivity work
✓ Contact Access Now's Digital Security Helpline or Citizen Lab if you suspect infection
✓ Run MVT on your device backup quarterly if you are a journalist or activist
✓ Brief your colleagues and sources — a compromised contact can expose your network

11. Will This Affect Users in 2026? — Definitive Answer

2026 Threat Assessment
FORCEDENTRY (CVE-2021-30860) itself: PATCHED since September 2021 (iOS 14.8). If you are running iOS 14.8 or later, you are not vulnerable to the specific FORCEDENTRY exploit analyzed in this document. Pegasus and Pegasus-style zero-click attacks in 2026: ACTIVELY ONGOING. NSO Group and at least 6 other commercial surveillance vendors are selling Pegasus-equivalent tools as of 2026. New zero-days are being deployed continuously.
Latest active exploit chain (February 2026): CVE-2026-20700 (dyld) + CVE-2025-14174 + CVE-2025-43529 (WebKit) — a 3-CVE chain actively exploited in the wild. Affects ALL iOS versions before iOS 26. Added to CISA's Known Exploited Vulnerabilities list. Who is at risk in 2026: The same categories targeted since 2016 — journalists, activists, lawyers, politicians, executives, and their associates. The general public faces lower direct risk from Pegasus-grade tools. However, the 'Coruna' exploit kit proliferating to criminal groups signals expanding risk. Bottom line: Update to iOS 26 now. Enable Lockdown Mode if you are a high-risk individual. The threat has not diminished — it has grown.

The commercial spyware industry is in a new phase. For the first time in 2025, commercial surveillance vendors — not nation-states — were the leading source of novel zero-day exploits in Google TAG's annual tracking. This is a structural shift: sophisticated attack capabilities are now commoditized and available to any government that can pay the licensing fee, removing the technical barrier that previously limited zero-click surveillance to the most well-resourced intelligence agencies.

Apple's response has been increasingly aggressive: iOS 26 patches 26 separate vulnerabilities, the company sends targeted notifications to suspected spyware victims in dozens of countries, and legal actions against NSO Group have succeeded in obtaining significant judgments. Yet the fundamental cat-and-mouse dynamic continues. Every major iOS update that closes known exploits also introduces new code that NSO and others begin probing for the next generation of zero-days.

FINAL WORD	The most important thing you can do in 2026 is update to the latest iOS version immediately whenever Apple releases an update, and enable Lockdown Mode if you have any reason to believe you are a high-value target. These two steps address the primary known vectors for both FORCEDENTRY-class exploits and the active 2026 exploit chains. The threat is real, it is ongoing, and it continues to evolve.

**********End Of Document**********